HRMS

01 IAM 認證授權 — API 規格書

目錄

HR01 IAM Service — API Specification

系統名稱	版本
人力資源暨專案管理系統	**1.0**
日期	作者
2026-03-06	**HRMS 開發團隊**

HR01 IAM服務 API詳細規格

版本: 1.1 **日期:** 2025-12-29（最後更新：2026-03-05） **服務代碼:** HR01 **服務名稱:** IAM服務 (Identity & Access Management)

目錄

1. API總覽
2. 認證API
3. 使用者管理API
4. 角色管理API
5. 權限管理API
6. 個人資料API
7. 系統管理API — 功能開關
8. 系統管理API — 系統參數
9. 系統管理API — 排程管理
10. 錯誤碼總覽
11. 領域事件總覽

1. API總覽

1.1 Controller命名對照

Controller	說明	負責頁面
`HR01AuthCmdController`	認證Command操作	HR01-P01 登入頁面
`HR01UserCmdController`	使用者Command操作	HR01-P02 使用者管理
`HR01UserQryController`	使用者Query操作	HR01-P02 使用者管理
`HR01RoleCmdController`	角色Command操作	HR01-P03 角色權限管理
`HR01RoleQryController`	角色Query操作	HR01-P03 角色權限管理
`HR01PermissionQryController`	權限Query操作	HR01-P03 角色權限管理
`HR01ProfileCmdController`	個人資料Command操作	HR01-P04 密碼修改
`HR01ProfileQryController`	個人資料Query操作	HR01-P04 密碼修改
`HR01SystemFeatureCmdController`	功能開關Command操作	HR01-P05 系統管理
`HR01SystemFeatureQryController`	功能開關Query操作	HR01-P05 系統管理
`HR01SystemConfigCmdController`	系統參數Command操作	HR01-P05 系統管理
`HR01SystemConfigQryController`	系統參數Query操作	HR01-P05 系統管理
`HR01SystemSchedulerCmdController`	排程管理Command操作	HR01-P05 系統管理
`HR01SystemSchedulerQryController`	排程管理Query操作	HR01-P05 系統管理

1.2 API總覽 (41個端點)

端點	方法	Controller	說明	權限
`/api/v1/auth/login`	POST	HR01AuthCmdController	登入	-
`/api/v1/auth/logout`	POST	HR01AuthCmdController	登出	-
`/api/v1/auth/refresh-token`	POST	HR01AuthCmdController	刷新Token	-
`/api/v1/auth/forgot-password`	POST	HR01AuthCmdController	忘記密碼	-
`/api/v1/auth/reset-password`	POST	HR01AuthCmdController	重置密碼	-
`/api/v1/auth/oauth/google`	GET	HR01AuthCmdController	Google OAuth	-
`/api/v1/auth/oauth/google/callback`	GET	HR01AuthCmdController	Google回調	-
`/api/v1/auth/oauth/microsoft`	GET	HR01AuthCmdController	Microsoft OAuth	-
`/api/v1/auth/oauth/microsoft/callback`	GET	HR01AuthCmdController	Microsoft回調	-
`/api/v1/users`	GET	HR01UserQryController	查詢使用者列表	user:read
`/api/v1/users/{id}`	GET	HR01UserQryController	查詢使用者詳情	user:read
`/api/v1/users`	POST	HR01UserCmdController	建立使用者	user:create
`/api/v1/users/{id}`	PUT	HR01UserCmdController	更新使用者	user:write
`/api/v1/users/{id}/deactivate`	PUT	HR01UserCmdController	停用使用者	user:deactivate
`/api/v1/users/{id}/activate`	PUT	HR01UserCmdController	啟用使用者	user:deactivate
`/api/v1/users/{id}/reset-password`	PUT	HR01UserCmdController	管理員重置密碼	user:reset-password
`/api/v1/users/{id}/roles`	PUT	HR01UserCmdController	指派角色	user:assign-role

端點	方法	Controller	說明	權限
`/api/v1/users/batch-deactivate`	PUT	HR01UserCmdController	批次停用	user:deactivate
`/api/v1/roles`	GET	HR01RoleQryController	查詢角色列表	role:read
`/api/v1/roles/{id}`	GET	HR01RoleQryController	查詢角色詳情	role:read
`/api/v1/roles`	POST	HR01RoleCmdController	建立角色	role:create
`/api/v1/roles/{id}`	PUT	HR01RoleCmdController	更新角色	role:write
`/api/v1/roles/{id}`	DELETE	HR01RoleCmdController	刪除角色	role:delete
`/api/v1/roles/{id}/permissions`	PUT	HR01RoleCmdController	更新角色權限	role:manage-permission
`/api/v1/permissions`	GET	HR01PermissionQryController	查詢權限列表	permission:read
`/api/v1/permissions/tree`	GET	HR01PermissionQryController	查詢權限樹	permission:read
`/api/v1/profile`	GET	HR01ProfileQryController	查詢個人資料	-
`/api/v1/profile`	PUT	HR01ProfileCmdController	更新個人資料	-
`/api/v1/profile/change-password`	PUT	HR01ProfileCmdController	修改密碼	-
`/api/v1/iam/system/features`	GET	HR01SystemFeatureQryController	查詢功能開關列表	system:feature:read
`/api/v1/iam/system/features/{featureId}`	GET	HR01SystemFeatureQryController	查詢功能開關詳情	system:feature:read
`/api/v1/iam/system/features/{featureId}`	PUT	HR01SystemFeatureCmdController	更新功能開關	system:feature:write
`/api/v1/iam/system/features/{featureId}/toggle`	PUT	HR01SystemFeatureCmdController	切換功能開關	system:feature:write
`/api/v1/iam/system/configs`	GET	HR01SystemConfigQryController	查詢系統參數列表	system:config:read
`/api/v1/iam/system/configs/{configId}`	GET	HR01SystemConfigQryController	查詢系統參數詳情	system:config:read

端點	方法	Controller	說明	權限
`/api/v1/iam/system/configs/{configId}`	PUT	HR01SystemConfigCmdController	更新系統參數	system:config:write
`/api/v1/iam/system/configs/{configId}/reset`	PUT	HR01SystemConfigCmdController	重設系統參數為預設值	system:config:write
`/api/v1/iam/system/schedulers`	GET	HR01SystemSchedulerQueryController	查詢排程列表	system:scheduler:read
`/api/v1/iam/system/schedulers/{schedulerId}`	GET	HR01SystemSchedulerQueryController	查詢排程詳情	system:scheduler:read
`/api/v1/iam/system/schedulers/{schedulerId}`	PUT	HR01SystemSchedulerCmdController	更新排程配置	system:scheduler:write
`/api/v1/iam/system/schedulers/{schedulerId}/trigger`	POST	HR01SystemSchedulerCmdController	手動觸發排程	system:scheduler:execute

2. 認證API

2.1 登入

基本資訊

項目	內容
端點	`POST /api/v1/auth/login`
Controller	`HR01AuthCmdController`
Service	`LoginServiceImpl`
權限	(公開，無需認證)
版本	v1

用途說明

使用者輸入帳號密碼進行身份驗證，驗證成功後取得 JWT Token 用於後續 API 呼叫。支援多租戶環境，可指定登入的租戶。

業務邏輯

1. **驗證請求資料**
    - username 必填，Email 格式
    - password 必填，8~128 字元

2. **查詢使用者**
   - 依據 username + tenantId 查詢使用者
   - 若使用者不存在，返回 INVALID_CREDENTIALS 錯誤
3. **檢查帳號狀態**
   - 若狀態為 INACTIVE，返回 ACCOUNT_DISABLED 錯誤
   - 若狀態為 LOCKED，檢查 lockedUntil 是否已過期
     - 已過期則自動解鎖
     - 未過期則返回 ACCOUNT_LOCKED 錯誤
4. **驗證密碼**
   - 使用 BCrypt 比對密碼
   - 密碼錯誤則 failedLoginAttempts + 1
   - 若 failedLoginAttempts >= 5，鎖定帳號 30 分鐘
5. **登入成功處理**
   - 更新 lastLoginAt
   - 重設 failedLoginAttempts = 0
   - 產生 Access Token (有效期 1 小時)
   - 產生 Refresh Token (有效期 7 天)
   - 儲存 Refresh Token 至資料庫
   - 記錄登入日誌
6. **發布事件**
   - 發布 UserLoggedInEvent

Request

Headers

名稱	必填	說明
Content-Type	✅	`application/json`

Request Body

欄位	類型	必填	驗證規則	說明	範例
username	String	✅	Email格式，最長255字元	登入帳號	`"john.doe@company.com"`
password	String	✅	8~128字元	密碼	`"Password123!"`
tenantId	UUID	⬚	UUID格式，預設為母公司	租戶ID	`"tenant-uuid"`

範例：

```
{
  "username": "john.doe@company.com",
  "password": "Password123!",
  "tenantId": "550e8400-e29b-41d4-a716-446655440000"
}
```

Response

成功回應 (200 OK)

欄位	類型	說明
accessToken	String	JWT Access Token
refreshToken	String	Refresh Token
expiresIn	Integer	Access Token 有效秒數
tokenType	String	Token 類型 (Bearer)
user	Object	使用者基本資訊
user.userId	UUID	使用者ID
user.username	String	登入帳號
user.displayName	String	顯示名稱
user.employeeId	UUID	關聯員工ID
user.roles	String[]	角色代碼列表
user.permissions	String[]	權限代碼列表

```json
{
  "code": "SUCCESS",
  "message": "登入成功",
  "data": {
    "accessToken": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
    "refreshToken": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
    "expiresIn": 3600,
    "tokenType": "Bearer",
    "user": {
      "userId": "550e8400-e29b-41d4-a716-446655440001",
      "username": "john.doe@company.com",
      "displayName": "John Doe",
      "employeeId": "550e8400-e29b-41d4-a716-446655440002",
      "roles": ["HR_ADMIN", "EMPLOYEE"],
      "permissions": ["user:read", "user:write", "employee:profile:read"]
    }
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
400	VALIDATION_EMAIL_FORMAT	Email格式不正確	檢查username格式
400	VALIDATION_PASSWORD_REQUIRED	密碼為必填	輸入密碼
401	AUTH_INVALID_CREDENTIALS	使用者名稱或密碼錯誤	確認帳號密碼
403	AUTH_ACCOUNT_DISABLED	帳號已停用	聯繫管理員啟用帳號
423	AUTH_ACCOUNT_LOCKED	帳號已被鎖定	等待30分鐘後重試或聯繫管理員

領域事件

事件名稱	Topic	說明
UserLoggedInEvent	`iam.user.logged-in`	使用者登入成功

2.2 登出

基本資訊

項目	內容
端點	`POST /api/v1/auth/logout`
Controller	`HR01AuthCmdController`
Service	`LogoutServiceImpl`
權限	(已認證即可)
版本	v1

用途說明

使用者登出系統，刪除 Refresh Token 使其失效。

業務邏輯

1. 從 Token 中取得使用者ID
2. 刪除該使用者的 Refresh Token
3. 記錄登出日誌

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Response

成功回應 (204 No Content)

無回應內容

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入

2.3 刷新Token

基本資訊

項目	內容
端點	`POST /api/v1/auth/refresh-token`
Controller	`HR01AuthCmdController`
Service	`RefreshTokenServiceImpl`
權限	(公開，無需認證)
版本	v1

用途說明

Access Token 過期時，使用 Refresh Token 取得新的 Access Token。

業務邏輯

1. **驗證 Refresh Token**
   - 解碼並驗證 Token 簽章
   - 檢查 Token 是否存在於資料庫
   - 檢查 Token 是否過期
2. **檢查使用者狀態**
   - 使用者必須存在且狀態為 ACTIVE
3. **產生新 Token**
   - 產生新的 Access Token
   - 產生新的 Refresh Token (輪換)
   - 刪除舊的 Refresh Token
   - 儲存新的 Refresh Token

Request

Headers

名稱	必填	說明
Content-Type	✅	`application/json`

Request Body

欄位	類型	必填	驗證規則	說明	範例
refreshToken	String	✅	有效的JWT格式	Refresh Token	`"eyJhbG..."`

範例：

```
{
  "refreshToken": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9..."
}
```

Response

成功回應 (200 OK)

欄位	類型	說明
accessToken	String	新的 Access Token
refreshToken	String	新的 Refresh Token
expiresIn	Integer	Access Token 有效秒數

```
{
  "code": "SUCCESS",
  "message": "Token刷新成功",
  "data": {
    "accessToken": "eyJhbGciOiJIUzI1NiIs...",
    "refreshToken": "eyJhbGciOiJIUzI1NiIs...",
    "expiresIn": 3600
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_REFRESH_TOKEN_INVALID	Refresh Token無效	重新登入
401	AUTH_REFRESH_TOKEN_EXPIRED	Refresh Token已過期	重新登入
403	AUTH_ACCOUNT_DISABLED	帳號已停用	聯繫管理員

2.4 忘記密碼

基本資訊

項目	內容
端點	`POST /api/v1/auth/forgot-password`
Controller	`HR01AuthCmdController`
Service	`ForgotPasswordServiceImpl`
權限	(公開，無需認證)
版本	v1

用途說明

使用者忘記密碼時，發送密碼重置連結至註冊 Email。

業務邏輯

1. **驗證 Email**
   - Email 必須存在於系統中
   - 不透露使用者是否存在（安全考量，統一回應成功）
2. **產生重置Token**
   - 產生隨機 Token (有效期 1 小時)
   - 儲存 Token 至資料庫
3. **發送郵件**
   - 發布 PasswordResetRequestedEvent
   - Notification Service 接收後發送郵件

Request

Headers

名稱	必填	說明
Content-Type	✅	`application/json`

Request Body

欄位	類型	必填	驗證規則	說明	範例
email	String	✅	Email格式	使用者Email	`"john.doe@company.com"`

範例：

```
{
  "email": "john.doe@company.com"
}
```

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "若此Email已註冊，您將收到密碼重置郵件",
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
400	VALIDATION_EMAIL_FORMAT	Email格式不正確	檢查Email格式

領域事件

事件名稱	Topic	說明
PasswordResetRequestedEvent	`iam.password.reset-requested`	密碼重置請求

2.5 重置密碼

基本資訊

項目	內容
端點	`POST /api/v1/auth/reset-password`
Controller	`HR01AuthCmdController`
Service	`ResetPasswordServiceImpl`
權限	(公開，無需認證)
版本	v1

用途說明

使用者透過密碼重置郵件中的連結，設定新密碼。

業務邏輯

1. **驗證 Token**
   - Token 必須存在且未過期
   - Token 只能使用一次
2. **驗證新密碼**
   - 符合密碼強度規則
3. **重置密碼**
   - 更新密碼
   - 更新 passwordChangedAt
   - 刪除重置 Token
   - 發布 PasswordResetEvent

Request

Headers

名稱	必填	說明
Content-Type	✅	`application/json`

Request Body

欄位	類型	必填	驗證規則	說明	範例
token	String	✅	有效的重置Token	郵件中的Token	`"abc123..."`
newPassword	String	✅	8~128字元，含大小寫+數字	新密碼	`"NewP@ss123"`
confirmPassword	String	✅	必須與newPassword相同	確認密碼	`"NewP@ss123"`

範例：

```
{
  "token": "abc123def456...",
  "newPassword": "NewP@ssword123!",
  "confirmPassword": "NewP@ssword123!"
}
```

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "密碼重置成功，請使用新密碼登入",
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
400	VALIDATION_PASSWORD_WEAK	密碼強度不足	密碼需含大小寫+數字
400	VALIDATION_PASSWORD_MISMATCH	兩次密碼不一致	確認密碼輸入一致
400	AUTH_RESET_TOKEN_INVALID	重置Token無效	重新申請密碼重置
400	AUTH_RESET_TOKEN_EXPIRED	重置Token已過期	重新申請密碼重置

領域事件

事件名稱	Topic	說明
PasswordResetEvent	`iam.password.reset`	密碼已重置

2.6 Google OAuth 登入

基本資訊

項目	內容
端點	`GET /api/v1/auth/oauth/google`
Controller	`HR01AuthCmdController`
Service	`GoogleOAuthServiceImpl`
權限	(公開，無需認證)
版本	v1

用途說明

重導向至 Google OAuth 授權頁面進行單一登入。

業務邏輯

1. 產生 OAuth state 參數（防 CSRF）
2. 建構 Google OAuth 授權 URL

3. 重導向使用者至 Google

Request

Query Parameters

參數名	類型	必填	說明	範例
redirect	String	☐	登入成功後重導向URL	`/dashboard`

Response

成功回應 (302 Found)

重導向至 Google OAuth 授權頁面

2.7 Google OAuth 回調

基本資訊

項目	內容
端點	`GET /api/v1/auth/oauth/google/callback`
Controller	`HR01AuthCmdController`
Service	`GoogleOAuthCallbackServiceImpl`
權限	(公開，無需認證)
版本	v1

用途說明

處理 Google OAuth 授權回調，完成使用者登入或帳號綁定。

業務邏輯

1. **驗證 OAuth 回應**
   - 驗證 state 參數
   - 使用 authorization code 換取 access token
   - 取得使用者資訊
2. **帳號處理**
   - 若 Google Email 已綁定帳號 → 直接登入
   - 若未綁定 → 嘗試自動綁定或導向綁定頁面
3. **產生 Token**
   - 產生 JWT Token

- 重導向回前端

Request

Query Parameters

參數名	類型	必填	說明	範例
code	String	✅	Google授權碼	`"4/0AY0e-g..."`
state	String	✅	CSRF保護參數	`"abc123"`
error	String	⬚	錯誤代碼（授權失敗時）	`"access_denied"`

Response

成功回應 (302 Found)

重導向至前端頁面，URL 中帶有 Token 參數

2.8 Microsoft OAuth 登入

基本資訊

項目	內容
端點	`GET /api/v1/auth/oauth/microsoft`
Controller	`HR01AuthCmdController`
Service	`MicrosoftOAuthServiceImpl`
權限	(公開，無需認證)
版本	v1

用途說明

重導向至 Microsoft OAuth 授權頁面進行單一登入。

業務邏輯

與 Google OAuth 流程相同，改用 Microsoft 授權端點。

2.9 Microsoft OAuth 回調

基本資訊

項目	內容
端點	`GET /api/v1/auth/oauth/microsoft/callback`
Controller	`HR01AuthCmdController`
Service	`MicrosoftOAuthCallbackServiceImpl`
權限	(公開，無需認證)
版本	v1

用途說明

處理 Microsoft OAuth 授權回調。

---

3. 使用者管理API

3.1 查詢使用者列表

基本資訊

項目	內容
端點	`GET /api/v1/users`
Controller	`HR01UserQryController`
Service	`GetUserListServiceImpl`
權限	`user:read`
版本	v1

用途說明

HR管理員查詢系統使用者列表，支援分頁、搜尋與篩選。

業務邏輯

1. **權限檢查**
    - 必須擁有 user:read 權限
2. **資料篩選**
    - 只能查詢同租戶的使用者
    - 依搜尋條件篩選
3. **回傳分頁資料**

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Query Parameters

參數名	類型	必填	預設值	說明	範例
page	Integer	⬚	1	頁碼（從1開始）	`1`
size	Integer	⬚	10	每頁筆數（最大100）	`20`
sort	String	⬚	createdAt,desc	排序欄位與方向	`username,asc`
search	String	⬚	-	搜尋關鍵字（username/email）	`john`
status	Enum	⬚	-	狀態篩選	`ACTIVE`
roleId	UUID	⬚	-	角色篩選	`"role-uuid"`
departmentId	UUID	⬚	-	部門篩選	`"dept-uuid"`

Response

成功回應 (200 OK)

欄位	類型	說明
content	Array	使用者列表
content[].userId	UUID	使用者ID
content[].username	String	登入帳號
content[].email	String	Email
content[].employeeId	UUID	關聯員工ID
content[].employeeName	String	員工姓名
content[].department	String	部門名稱
content[].roles	Array	角色列表
content[].status	Enum	帳號狀態
content[].lastLoginAt	DateTime	最後登入時間
content[].createdAt	DateTime	建立時間
page	Integer	當前頁碼
size	Integer	每頁筆數
totalElements	Long	總筆數
totalPages	Integer	總頁數

```json
{
  "code": "SUCCESS",
  "message": "查詢成功",
  "data": {
    "content": [
      {
        "userId": "550e8400-e29b-41d4-a716-446655440001",
        "username": "john.doe@company.com",
        "email": "john.doe@company.com",
        "employeeId": "550e8400-e29b-41d4-a716-446655440010",
        "employeeName": "John Doe",
        "department": "人力資源部",
        "roles": [
          {"roleId": "role-uuid-1", "roleName": "HR_ADMIN", "displayName": "人資管理員"}
        ],
        "status": "ACTIVE",
        "lastLoginAt": "2025-12-29T09:00:00Z",
        "createdAt": "2025-01-15T10:30:00Z"
      }
    ],
    "page": 1,
    "size": 10,
    "totalElements": 156,
    "totalPages": 16
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無user:read權限	聯繫管理員授權

3.2 查詢使用者詳情

基本資訊

項目	內容
端點	`GET /api/v1/users/{id}`
Controller	`HR01UserQryController`
Service	`GetUserDetailServiceImpl`
權限	`user:read`
版本	v1

用途說明

查詢單一使用者的詳細資料，包含角色權限資訊。

業務邏輯

1. **權限檢查**
   - 必須擁有 user:read 權限
   - 只能查詢同租戶的使用者
2. **查詢使用者**
   - 使用者不存在則返回 404

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Path Parameters

參數名	類型	必填	說明	範例
id	UUID	✅	使用者ID	`"550e8400-e29b-41d4-a716-446655440001"`

Response

成功回應 (200 OK)

欄位	類型	說明
userId	UUID	使用者ID
username	String	登入帳號
email	String	Email
employeeId	UUID	關聯員工ID
employeeName	String	員工姓名
department	String	部門名稱
tenantId	UUID	租戶ID
tenantName	String	租戶名稱
roles	Array	角色列表
status	Enum	帳號狀態
lastLoginAt	DateTime	最後登入時間
passwordChangedAt	DateTime	密碼最後修改時間
createdAt	DateTime	建立時間
updatedAt	DateTime	更新時間

```json
{
  "code": "SUCCESS",
  "message": "查詢成功",
  "data": {
    "userId": "550e8400-e29b-41d4-a716-446655440001",
    "username": "john.doe@company.com",
    "email": "john.doe@company.com",
    "employeeId": "550e8400-e29b-41d4-a716-446655440010",
    "employeeName": "John Doe",
    "department": "人力資源部",
    "tenantId": "550e8400-e29b-41d4-a716-446655440000",
    "tenantName": "母公司",
    "roles": [
      {
        "roleId": "role-uuid-1",
        "roleName": "HR_ADMIN",
        "displayName": "人資管理員"
      },
      {
        "roleId": "role-uuid-2",
        "roleName": "EMPLOYEE",
        "displayName": "一般員工"
      }
    ],
    "status": "ACTIVE",
    "lastLoginAt": "2025-12-29T09:00:00Z",
    "passwordChangedAt": "2025-12-01T10:00:00Z",
    "createdAt": "2025-01-15T10:30:00Z",
    "updatedAt": "2025-12-15T14:00:00Z"
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無user:read權限	聯繫管理員授權
404	RESOURCE_USER_NOT_FOUND	使用者不存在	確認使用者ID

3.3 建立使用者

基本資訊

項目	內容
端點	`POST /api/v1/users`
Controller	`HR01UserCmdController`
Service	`CreateUserServiceImpl`
權限	`user:create`
版本	v1

用途說明

HR管理員建立新的系統使用者帳號。新使用者會收到一封包含臨時密碼的歡迎郵件，首次登入時必須修改密碼。

業務邏輯

1. **驗證請求資料**
   - username 必須為有效 Email 格式
   - username 在同一 tenant 內必須唯一
   - employeeId 必須存在於 Organization 服務
   - roleIds 至少指定一個角色，所有角色必須存在
2. **建立使用者**
   - 產生 UUID 作為 userId
   - 產生 8 位隨機臨時密碼（含大小寫+數字）
   - 密碼使用 BCrypt 加密後儲存
   - 設定 status = ACTIVE
   - 設定 passwordChangedAt = null（強制首次登入改密碼）
3. **建立角色關聯**
   - 在 user_roles 表建立使用者與角色的關聯
4. **發送通知**
   - 若 sendWelcomeEmail = true，發送歡迎郵件含臨時密碼
   - 發布 UserCreatedEvent 至 Kafka

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`
Content-Type	✅	`application/json`

Request Body

欄位	類型	必填	驗證規則	說明	範例
username	String	✅	Email格式，最長255字元，tenant內唯一	登入帳號	`"jane.doe@company.com"`
email	String	✅	Email格式，最長255字元	使用者電子郵件	`"jane.doe@company.com"`
employeeId	UUID	✅	必須存在於Organization服務	關聯員工ID	`"emp-uuid-001"`
roleIds	UUID[]	✅	1~10個，所有ID必須存在	指派角色ID列表	`["role-uuid-1"]`
sendWelcomeEmail	Boolean	⬚	-	是否發送歡迎郵件（預設true）	`true`

範例：

```
{
  "username": "jane.doe@company.com",
  "email": "jane.doe@company.com",
  "employeeId": "550e8400-e29b-41d4-a716-446655440001",
  "roleIds": ["00000000-0000-0000-0000-000000000007"],
  "sendWelcomeEmail": true
}
```

Response

成功回應 (201 Created)

欄位	類型	說明
userId	UUID	新建使用者ID
username	String	登入帳號
status	Enum	帳號狀態（ACTIVE）
createdAt	DateTime	建立時間

```json
{
  "code": "SUCCESS",
  "message": "使用者建立成功",
  "data": {
    "userId": "550e8400-e29b-41d4-a716-446655440099",
    "username": "jane.doe@company.com",
    "status": "ACTIVE",
    "createdAt": "2025-12-29T10:30:00Z"
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
400	VALIDATION_EMAIL_FORMAT	Email格式不正確	檢查username/email格式
400	VALIDATION_ROLE_REQUIRED	至少需指派一個角色	在roleIds中加入角色ID
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無user:create權限	聯繫管理員授權
404	RESOURCE_EMPLOYEE_NOT_FOUND	員工不存在	確認employeeId正確性
404	RESOURCE_ROLE_NOT_FOUND	角色不存在	確認roleIds正確性
409	RESOURCE_USER_EXISTS	使用者帳號已存在	使用其他帳號名稱
409	RESOURCE_EMPLOYEE_HAS_USER	該員工已有帳號	一個員工只能有一個帳號

領域事件

事件名稱	Topic	說明
UserCreatedEvent	`iam.user.created`	使用者建立完成，通知其他服務

事件 Payload：

```json
{
  "eventId": "evt-uuid-001",
  "eventType": "UserCreatedEvent",
  "occurredAt": "2025-12-29T10:30:00Z",
  "aggregateId": "550e8400-e29b-41d4-a716-446655440099",
  "aggregateType": "User",
  "payload": {
    "userId": "550e8400-e29b-41d4-a716-446655440099",
    "username": "jane.doe@company.com",
    "email": "jane.doe@company.com",
    "employeeId": "550e8400-e29b-41d4-a716-446655440001",
    "tenantId": "tenant-uuid-001",
    "roleIds": ["00000000-0000-0000-0000-000000000007"]
  }
}
```

3.4 更新使用者

基本資訊

項目	內容
端點	`PUT /api/v1/users/{id}`
Controller	`HR01UserCmdController`
Service	`UpdateUserServiceImpl`
權限	`user:write`
版本	v1

用途說明

更新使用者的基本資料（Email）。帳號名稱（username）建立後不可修改。

業務邏輯

1. **權限檢查**
   - 必須擁有 user:write 權限
2. **驗證請求資料**
   - email 必須為有效 Email 格式
3. **更新使用者**
   - 更新 email
   - 更新 updatedAt

- 發布 UserUpdatedEvent

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`
Content-Type	✅	`application/json`

Path Parameters

參數名	類型	必填	說明	範例
id	UUID	✅	使用者ID	`"550e8400-..."`

Request Body

欄位	類型	必填	驗證規則	說明	範例
email	String	⬚	Email格式	使用者Email	`"john.new@company.com"`

範例：

```
{
  "email": "john.new@company.com"
}
```

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "使用者更新成功",
  "data": {
    "userId": "550e8400-e29b-41d4-a716-446655440001",
    "email": "john.new@company.com",
    "updatedAt": "2025-12-29T10:30:00Z"
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
400	VALIDATION_EMAIL_FORMAT	Email格式不正確	檢查Email格式
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無user:write權限	聯繫管理員授權
404	RESOURCE_USER_NOT_FOUND	使用者不存在	確認使用者ID

領域事件

事件名稱	Topic	說明
UserUpdatedEvent	`iam.user.updated`	使用者資料已更新

3.5 停用使用者

基本資訊

項目	內容
端點	`PUT /api/v1/users/{id}/deactivate`
Controller	`HR01UserCmdController`
Service	`DeactivateUserServiceImpl`
權限	`user:deactivate`
版本	v1

用途說明

停用使用者帳號，停用後該使用者將無法登入系統。通常用於員工離職或帳號異常情況。

業務邏輯

1. **權限檢查**
   - 必須擁有 user:deactivate 權限
2. **停用使用者**
   - 更新 status = INACTIVE
   - 刪除該使用者的所有 Refresh Token
   - 發布 UserDeactivatedEvent

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Path Parameters

參數名	類型	必填	說明	範例
id	UUID	✅	使用者ID	`"550e8400-..."`

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "使用者已停用",
  "data": {
    "userId": "550e8400-e29b-41d4-a716-446655440001",
    "status": "INACTIVE",
    "deactivatedAt": "2025-12-29T10:30:00Z"
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無user:deactivate權限	聯繫管理員授權
404	RESOURCE_USER_NOT_FOUND	使用者不存在	確認使用者ID
422	BUSINESS_USER_ALREADY_INACTIVE	使用者已停用	無需再次停用

領域事件

事件名稱	Topic	說明
UserDeactivatedEvent	`iam.user.deactivated`	使用者已停用，通知其他服務清理權限

3.6 啟用使用者

基本資訊

項目	內容
端點	`PUT /api/v1/users/{id}/activate`
Controller	`HR01UserCmdController`
Service	`ActivateUserServiceImpl`
權限	`user:deactivate`
版本	v1

用途說明

重新啟用已停用或鎖定的使用者帳號。

業務邏輯

1. **權限檢查**
   - 必須擁有 user:deactivate 權限
2. **啟用使用者**
   - 更新 status = ACTIVE
   - 重設 failedLoginAttempts = 0
   - 清除 lockedUntil
   - 發布 UserActivatedEvent

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Path Parameters

參數名	類型	必填	說明	範例
id	UUID	✅	使用者ID	`"550e8400-..."`

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "使用者已啟用",
  "data": {
    "userId": "550e8400-e29b-41d4-a716-446655440001",
    "status": "ACTIVE",
    "activatedAt": "2025-12-29T10:30:00Z"
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無user:deactivate權限	聯繫管理員授權
404	RESOURCE_USER_NOT_FOUND	使用者不存在	確認使用者ID
422	BUSINESS_USER_ALREADY_ACTIVE	使用者已啟用	無需再次啟用

領域事件

事件名稱	Topic	說明
UserActivatedEvent	`iam.user.activated`	使用者已啟用

3.7 管理員重置密碼

基本資訊

項目	內容
端點	`PUT /api/v1/users/{id}/reset-password`
Controller	`HR01UserCmdController`
Service	`AdminResetPasswordServiceImpl`
權限	`user:reset-password`
版本	v1

用途說明

管理員為使用者重置密碼，通常用於使用者忘記密碼且無法透過 Email 重置的情況。

業務邏輯

1. **權限檢查**
   - 必須擁有 user:reset-password 權限
2. **產生新密碼**
   - 產生 8 位隨機臨時密碼
   - 使用 BCrypt 加密儲存
3. **設定強制修改**
   - 設定 passwordChangedAt = null（強制首次登入改密碼）
   - 發布 PasswordResetByAdminEvent

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`
Content-Type	✅	`application/json`

Path Parameters

參數名	類型	必填	說明	範例
id	UUID	✅	使用者ID	`"550e8400-..."`

Request Body

欄位	類型	必填	驗證規則	說明	範例
newPassword	String	⬚	8~128字元，含大小寫+數字（若不填則自動產生）	新密碼	`"NewTemp@123"`
sendNotification	Boolean	⬚	-	是否發送通知郵件（預設true）	`true`

範例：

```
{
  "newPassword": "NewTemp@123",
  "sendNotification": true
}
```

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "密碼已重置",
  "data": {
    "userId": "550e8400-e29b-41d4-a716-446655440001",
    "temporaryPassword": "Temp@8a9b",
    "requireChangeOnLogin": true
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
400	VALIDATION_PASSWORD_WEAK	密碼強度不足	密碼需含大小寫+數字
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無user:reset-password權限	聯繫管理員授權
404	RESOURCE_USER_NOT_FOUND	使用者不存在	確認使用者ID

領域事件

事件名稱	Topic	說明
PasswordResetByAdminEvent	`iam.password.reset-by-admin`	管理員重置密碼

3.8 指派角色

基本資訊

項目	內容
端點	`PUT /api/v1/users/{id}/roles`
Controller	`HR01UserCmdController`
Service	`AssignUserRolesServiceImpl`
權限	`user:assign-role`
版本	v1

用途說明

為使用者指派或更新角色。會完全取代現有角色。

業務邏輯

1. **權限檢查**
   - 必須擁有 user:assign-role 權限
2. **驗證角色**
   - 所有 roleIds 必須存在
   - 至少指派一個角色
3. **更新角色**
   - 刪除現有 user_roles 記錄
   - 建立新的 user_roles 記錄
   - 發布 UserRoleAssignedEvent
   - 清除權限快取

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`
Content-Type	✅	`application/json`

Path Parameters

參數名	類型	必填	說明	範例
id	UUID	✅	使用者ID	`"550e8400-..."`

Request Body

欄位	類型	必填	驗證規則	說明	範例
roleIds	UUID[]	✅	1~10個，所有ID必須存在	角色ID列表	`["role-uuid-1", "role-uuid-2"]`

範例：

```
{
  "roleIds": [
    "00000000-0000-0000-0000-000000000002",
    "00000000-0000-0000-0000-000000000007"
  ]
}
```

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "角色指派成功",
  "data": {
    "userId": "550e8400-e29b-41d4-a716-446655440001",
    "roles": [
      {"roleId": "00000000-0000-0000-0000-000000000002", "roleName": "HR_ADMIN"},
      {"roleId": "00000000-0000-0000-0000-000000000007", "roleName": "EMPLOYEE"}
    ]
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
400	VALIDATION_ROLE_REQUIRED	至少需指派一個角色	在roleIds中加入角色ID
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無user:assign-role權限	聯繫管理員授權
404	RESOURCE_USER_NOT_FOUND	使用者不存在	確認使用者ID
404	RESOURCE_ROLE_NOT_FOUND	角色不存在	確認roleIds正確性

領域事件

事件名稱	Topic	說明
UserRoleAssignedEvent	`iam.user.role-assigned`	使用者角色已更新

3.9 批次停用使用者

基本資訊

項目	內容
端點	`PUT /api/v1/users/batch-deactivate`
Controller	`HR01UserCmdController`
Service	`BatchDeactivateUsersServiceImpl`
權限	`user:deactivate`
版本	v1

用途說明

批次停用多個使用者帳號，用於部門解散或大量離職處理。

業務邏輯

1. **權限檢查**
   - 必須擁有 user:deactivate 權限
2. **批次處理**
   - 逐一驗證使用者存在
   - 逐一停用使用者
   - 記錄成功與失敗的項目
3. **回傳結果**
   - 回傳成功停用的數量
   - 回傳失敗的項目與原因

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`
Content-Type	✅	`application/json`

Request Body

欄位	類型	必填	驗證規則	說明	範例
userIds	UUID[]	✅	1~100個	使用者ID列表	`["user-1", "user-2"]`

範例：

```
{
  "userIds": [
    "550e8400-e29b-41d4-a716-446655440001",
    "550e8400-e29b-41d4-a716-446655440002",
    "550e8400-e29b-41d4-a716-446655440003"
  ]
}
```

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "批次停用完成",
  "data": {
    "totalRequested": 3,
    "successCount": 2,
    "failedCount": 1,
    "results": [
      {"userId": "550e8400-...-001", "status": "SUCCESS"},
      {"userId": "550e8400-...-002", "status": "SUCCESS"},
      {"userId": "550e8400-...-003", "status": "FAILED", "reason": "使用者不存在"}
    ]
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
400	VALIDATION_USER_IDS_REQUIRED	至少需選擇一個使用者	在userIds中加入使用者ID
400	VALIDATION_USER_IDS_TOO_MANY	超過批次上限（100）	分批處理
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無user:deactivate權限	聯繫管理員授權

---

4. 角色管理API

4.1 查詢角色列表

基本資訊

項目	內容
端點	`GET /api/v1/roles`
Controller	`HR01RoleQryController`
Service	`GetRoleListServiceImpl`
權限	`role:read`
版本	v1

用途說明

查詢系統角色列表，包含系統預設角色與自訂角色。

業務邏輯

1. **權限檢查**
   - 必須擁有 role:read 權限
2. **資料查詢**
   - 查詢系統預設角色（tenantId = null）
   - 查詢當前租戶的自訂角色
   - 計算每個角色的使用者數量

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Query Parameters

參數名	類型	必填	預設值	說明	範例
includeSystemRoles	Boolean	⬚	true	是否包含系統預設角色	`true`
search	String	⬚	-	搜尋關鍵字	`"管理"`

Response

成功回應 (200 OK)

```json
{
  "code": "SUCCESS",
  "message": "查詢成功",
  "data": [
    {
      "roleId": "00000000-0000-0000-0000-000000000001",
      "roleName": "SYSTEM_ADMIN",
      "displayName": "系統管理員",
      "description": "最高權限，可管理所有功能",
      "isSystemRole": true,
      "userCount": 2,
      "permissionCount": 50
    },
    {
      "roleId": "00000000-0000-0000-0000-000000000002",
      "roleName": "HR_ADMIN",
      "displayName": "人資管理員",
      "description": "人資全功能權限",
      "isSystemRole": true,
      "userCount": 5,
      "permissionCount": 30
    }
  ],
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無role:read權限	聯繫管理員授權

4.2 查詢角色詳情

基本資訊

項目	內容
端點	`GET /api/v1/roles/{id}`
Controller	`HR01RoleQryController`
Service	`GetRoleDetailServiceImpl`
權限	`role:read`
版本	v1

用途說明

查詢單一角色的詳細資訊，包含權限列表。

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Path Parameters

參數名	類型	必填	說明	範例
id	UUID	✅	角色ID	`"00000000-0000-0000-0000-000000000002"`

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "查詢成功",
  "data": {
    "roleId": "00000000-0000-0000-0000-000000000002",
    "roleName": "HR_ADMIN",
    "displayName": "人資管理員",
    "description": "人資全功能權限",
    "isSystemRole": true,
    "userCount": 5,
    "permissions": [
      {
        "permissionId": "perm-uuid-1",
        "permissionCode": "user:read",
        "description": "查看使用者資料"
      },
      {
        "permissionId": "perm-uuid-2",
        "permissionCode": "user:create",
        "description": "建立使用者"
      }
    ],
    "createdAt": "2025-01-01T00:00:00Z",
    "updatedAt": "2025-12-15T10:00:00Z"
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無role:read權限	聯繫管理員授權
404	RESOURCE_ROLE_NOT_FOUND	角色不存在	確認角色ID

4.3 建立角色

基本資訊

項目	內容
端點	`POST /api/v1/roles`
Controller	`HR01RoleCmdController`
Service	`CreateRoleServiceImpl`
權限	`role:create`
版本	v1

用途說明

建立自訂角色，可為特定租戶建立專屬角色。

業務邏輯

1. **權限檢查**
   - 必須擁有 role:create 權限
2. **驗證請求資料**
   - roleName 在同一 tenant 內必須唯一
   - permissionIds 所有權限必須存在
3. **建立角色**
   - 產生 roleId
   - 建立 role_permissions 關聯
   - 發布 RoleCreatedEvent

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`
Content-Type	✅	`application/json`

Request Body

欄位	類型	必填	驗證規則	說明	範例
roleName	String	✅	英文大寫+底線，最長100字元，tenant內唯一	角色代碼	`"DEPT_MANAGER"`
displayName	String	✅	最長255字元	角色顯示名稱	`"部門主管"`
description	String	⬚	最長500字元	角色說明	`"部門管理權限"`
permissionIds	UUID[]	⬚	所有ID必須存在	權限ID列表	`["perm-1", "perm-2"]`

範例：

```
{
  "roleName": "DEPT_MANAGER",
  "displayName": "部門主管",
  "description": "部門管理權限，可審核部門員工假勤",
  "permissionIds": [
    "perm-uuid-1",
    "perm-uuid-2",
    "perm-uuid-3"
  ]
}
```

Response

成功回應 (201 Created)

```
{
  "code": "SUCCESS",
  "message": "角色建立成功",
  "data": {
    "roleId": "550e8400-e29b-41d4-a716-446655440099",
    "roleName": "DEPT_MANAGER",
    "displayName": "部門主管",
    "createdAt": "2025-12-29T10:30:00Z"
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
400	VALIDATION_ROLE_NAME_FORMAT	角色代碼格式不正確	使用英文大寫+底線
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無role:create權限	聯繫管理員授權
404	RESOURCE_PERMISSION_NOT_FOUND	權限不存在	確認permissionIds正確性
409	RESOURCE_ROLE_EXISTS	角色代碼已存在	使用其他角色代碼

領域事件

事件名稱	Topic	說明
RoleCreatedEvent	`iam.role.created`	角色已建立

4.4 更新角色

基本資訊

項目	內容
端點	`PUT /api/v1/roles/{id}`
Controller	`HR01RoleCmdController`
Service	`UpdateRoleServiceImpl`
權限	`role:write`
版本	v1

用途說明

更新角色的基本資訊（顯示名稱、說明）。系統預設角色不可修改。

業務邏輯

1. **權限檢查**
   - 必須擁有 role:write 權限
2. **驗證角色**
   - 角色必須存在
   - 系統預設角色不可修改
3. **更新角色**

- 更新 displayName、description
- 發布 RoleUpdatedEvent

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`
Content-Type	✅	`application/json`

Path Parameters

參數名	類型	必填	說明	範例
id	UUID	✅	角色ID	`"550e8400-..."`

Request Body

欄位	類型	必填	驗證規則	說明	範例
displayName	String	⬚	最長255字元	角色顯示名稱	`"資深部門主管"`
description	String	⬚	最長500字元	角色說明	`"更新後的說明"`

範例：

```
{
  "displayName": "資深部門主管",
  "description": "部門管理與人員考核權限"
}
```

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "角色更新成功",
  "data": {
    "roleId": "550e8400-e29b-41d4-a716-446655440099",
    "displayName": "資深部門主管",
    "updatedAt": "2025-12-29T10:30:00Z"
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無role:write權限	聯繫管理員授權
404	RESOURCE_ROLE_NOT_FOUND	角色不存在	確認角色ID
422	BUSINESS_SYSTEM_ROLE_READONLY	系統預設角色不可修改	只能修改自訂角色

領域事件

事件名稱	Topic	說明
RoleUpdatedEvent	`iam.role.updated`	角色已更新

4.5 刪除角色

基本資訊

項目	內容
端點	`DELETE /api/v1/roles/{id}`
Controller	`HR01RoleCmdController`
Service	`DeleteRoleServiceImpl`
權限	`role:delete`
版本	v1

用途說明

刪除自訂角色。系統預設角色不可刪除。若有使用者仍使用此角色則無法刪除。

業務邏輯

1. **權限檢查**
   - 必須擁有 role:delete 權限
2. **驗證角色**
   - 角色必須存在
   - 系統預設角色不可刪除
   - 沒有使用者使用此角色
3. **刪除角色**

- 刪除 role_permissions 關聯
- 刪除 roles 記錄
- 發布 RoleDeletedEvent

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Path Parameters

參數名	類型	必填	說明	範例
id	UUID	✅	角色ID	`"550e8400-..."`

Response

成功回應 (204 No Content)

無回應內容

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無role:delete權限	聯繫管理員授權
404	RESOURCE_ROLE_NOT_FOUND	角色不存在	確認角色ID
422	BUSINESS_SYSTEM_ROLE_READONLY	系統預設角色不可刪除	只能刪除自訂角色
422	BUSINESS_ROLE_IN_USE	角色仍有使用者使用	先移除使用者的角色指派

領域事件

事件名稱	Topic	說明
RoleDeletedEvent	`iam.role.deleted`	角色已刪除

4.6 更新角色權限

基本資訊

項目	內容
端點	`PUT /api/v1/roles/{id}/permissions`
Controller	`HR01RoleCmdController`
Service	`UpdateRolePermissionsServiceImpl`
權限	`role:manage-permission`
版本	v1

用途說明

更新角色的權限設定，會完全取代現有權限。系統預設角色的權限不可修改。

業務邏輯

1. **權限檢查**
   - 必須擁有 role:manage-permission 權限
2. **驗證請求資料**
   - 角色必須存在且非系統預設
   - 所有 permissionIds 必須存在
3. **更新權限**
   - 刪除現有 role_permissions 記錄
   - 建立新的 role_permissions 記錄
   - 發布 RolePermissionChangedEvent
   - 清除相關使用者的權限快取

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`
Content-Type	✅	`application/json`

Path Parameters

參數名	類型	必填	說明	範例
id	UUID	✅	角色ID	`"550e8400-..."`

Request Body

欄位	類型	必填	驗證規則	說明	範例
permissionIds	UUID[]	✅	所有ID必須存在	權限ID列表	`["perm-1", "perm-2"]`

範例：

```
{
  "permissionIds": [
    "perm-uuid-1",
    "perm-uuid-2",
    "perm-uuid-3"
  ]
}
```

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "角色權限更新成功",
  "data": {
    "roleId": "550e8400-e29b-41d4-a716-446655440099",
    "permissionCount": 3,
    "updatedAt": "2025-12-29T10:30:00Z"
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無role:manage-permission權限	聯繫管理員授權
404	RESOURCE_ROLE_NOT_FOUND	角色不存在	確認角色ID
404	RESOURCE_PERMISSION_NOT_FOUND	權限不存在	確認permissionIds正確性
422	BUSINESS_SYSTEM_ROLE_READONLY	系統預設角色權限不可修改	只能修改自訂角色

領域事件

事件名稱	Topic	說明
RolePermissionChangedEvent	`iam.role.permission-changed`	角色權限已變更，通知清除快取

5. 權限管理API

5.1 查詢權限列表

基本資訊

項目	內容
端點	`GET /api/v1/permissions`
Controller	`HR01PermissionQryController`
Service	`GetPermissionListServiceImpl`
權限	`permission:read`
版本	v1

用途說明

查詢系統所有權限定義，用於角色權限設定。

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Query Parameters

參數名	類型	必填	預設值	說明	範例
resource	String	⬚	-	資源類型篩選	`"user"`
search	String	⬚	-	搜尋關鍵字	`"read"`

Response

成功回應 (200 OK)

```json
{
  "code": "SUCCESS",
  "message": "查詢成功",
  "data": [
    {
      "permissionId": "perm-uuid-1",
      "permissionCode": "user:read",
      "resource": "user",
      "action": "read",
      "description": "查看使用者資料"
    },
    {
      "permissionId": "perm-uuid-2",
      "permissionCode": "user:create",
      "resource": "user",
      "action": "create",
      "description": "建立使用者"
    }
  ],
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無permission:read權限	聯繫管理員授權

5.2 查詢權限樹

基本資訊

項目	內容
端點	`GET /api/v1/permissions/tree`
Controller	`HR01PermissionQryController`
Service	`GetPermissionTreeServiceImpl`
權限	`permission:read`
版本	v1

用途說明

查詢權限樹狀結構，用於角色權限設定頁面的樹狀選擇器。

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "查詢成功",
  "data": [
    {
      "category": "使用者管理",
      "categoryCode": "user",
      "permissions": [
        {"permissionId": "perm-1", "permissionCode": "user:read", "displayName": "查看使用者
        {"permissionId": "perm-2", "permissionCode": "user:create", "displayName": "建立使用
        {"permissionId": "perm-3", "permissionCode": "user:write", "displayName": "編輯使用者
        {"permissionId": "perm-4", "permissionCode": "user:delete", "displayName": "刪除使用
      ]
    },
    {
      "category": "角色管理",
      "categoryCode": "role",
      "permissions": [
        {"permissionId": "perm-5", "permissionCode": "role:read", "displayName": "查看角色"
        {"permissionId": "perm-6", "permissionCode": "role:create", "displayName": "建立角色
      ]
    },
    {
      "category": "員工管理",
      "categoryCode": "employee",
      "permissions": [
        {"permissionId": "perm-7", "permissionCode": "employee:profile:read", "displayName"
        {"permissionId": "perm-8", "permissionCode": "employee:profile:write", "displayName
      ]
    }
  ],
  "timestamp": "2025-12-29T10:30:00Z"
}
```

6. 個人資料API

6.1 查詢個人資料

基本資訊

項目	內容
端點	`GET /api/v1/profile`
Controller	`HR01ProfileQryController`
Service	`GetProfileServiceImpl`
權限	(已認證即可)
版本	v1

用途說明

查詢當前登入使用者的個人資料。

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Response

成功回應 (200 OK)

```json
{
  "code": "SUCCESS",
  "message": "查詢成功",
  "data": {
    "userId": "550e8400-e29b-41d4-a716-446655440001",
    "username": "john.doe@company.com",
    "email": "john.doe@company.com",
    "employeeId": "550e8400-e29b-41d4-a716-446655440010",
    "employeeName": "John Doe",
    "department": "人力資源部",
    "roles": ["HR_ADMIN", "EMPLOYEE"],
    "permissions": ["user:read", "user:write", "employee:profile:read"],
    "lastLoginAt": "2025-12-29T09:00:00Z",
    "passwordChangedAt": "2025-12-01T10:00:00Z",
    "passwordExpiryDate": "2026-03-01T10:00:00Z",
    "isPasswordExpiringSoon": false
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入

6.2 更新個人資料

基本資訊

項目	內容
端點	`PUT /api/v1/profile`
Controller	`HR01ProfileCmdController`
Service	`UpdateProfileServiceImpl`
權限	(已認證即可)
版本	v1

用途說明

使用者更新自己的個人資料。

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`
Content-Type	✅	`application/json`

Request Body

欄位	類型	必填	驗證規則	說明	範例
email	String	⬚	Email格式	使用者Email	`"john.new@company.com"`

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "個人資料更新成功",
  "data": {
    "email": "john.new@company.com",
    "updatedAt": "2025-12-29T10:30:00Z"
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
400	VALIDATION_EMAIL_FORMAT	Email格式不正確	檢查Email格式
401	AUTH_TOKEN_INVALID	Token無效	重新登入

6.3 修改密碼

基本資訊

項目	內容
端點	`PUT /api/v1/profile/change-password`
Controller	`HR01ProfileCmdController`
Service	`ChangePasswordServiceImpl`
權限	(已認證即可)
版本	v1

用途說明

使用者修改自己的登入密碼。

業務邏輯

1. **驗證舊密碼**
   - 舊密碼必須正確
2. **驗證新密碼**
   - 符合密碼強度規則
   - 不可與舊密碼相同
   - 不可與近 3 次密碼相同
3. **更新密碼**
   - 更新 password_hash
   - 更新 passwordChangedAt
   - 發布 PasswordChangedEvent

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`
Content-Type	✅	`application/json`

Request Body

欄位	類型	必填	驗證規則	說明	範例
currentPassword	String	✅	-	當前密碼	`"OldP@ss123"`
newPassword	String	✅	8~128字元，含大小寫+數字	新密碼	`"NewP@ss456"`
confirmPassword	String	✅	必須與newPassword相同	確認新密碼	`"NewP@ss456"`

範例：

```
{
  "currentPassword": "OldP@ssword123!",
  "newPassword": "NewP@ssword456!",
  "confirmPassword": "NewP@ssword456!"
}
```

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "密碼修改成功",
  "data": {
    "passwordChangedAt": "2025-12-29T10:30:00Z",
    "passwordExpiryDate": "2026-03-29T10:30:00Z"
  },
  "timestamp": "2025-12-29T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
400	VALIDATION_PASSWORD_WEAK	密碼強度不足	密碼需含大小寫+數字
400	VALIDATION_PASSWORD_MISMATCH	兩次密碼不一致	確認密碼輸入一致
400	VALIDATION_PASSWORD_SAME_AS_OLD	新密碼不能與舊密碼相同	輸入不同的新密碼
400	VALIDATION_PASSWORD_RECENTLY_USED	新密碼不能與近3次密碼相同	輸入未使用過的密碼
401	AUTH_TOKEN_INVALID	Token無效	重新登入
401	AUTH_CURRENT_PASSWORD_WRONG	當前密碼錯誤	確認當前密碼

領域事件

事件名稱	Topic	說明
PasswordChangedEvent	`iam.password.changed`	密碼已修改

7. 系統管理API — 功能開關

7.1 查詢功能開關列表

基本資訊

項目	內容
端點	`GET /api/v1/iam/system/features`
Controller	`HR01SystemFeatureQryController`
Service	`GetFeatureListServiceImpl`
權限	`system:feature:read`
版本	v1

用途說明

查詢所有功能開關列表，支援依模組篩選。IT 管理員透過此 API 檢視各模組業務功能的啟停狀態，功能開關的變更即時生效，不需重啟服務。

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Query Parameters

參數名	類型	必填	說明	範例
module	String	⬚	模組代碼篩選（HR01-HR14）	`"HR03"`
enabled	Boolean	⬚	僅顯示啟用/停用的功能	`true`
keyword	String	⬚	模糊搜尋（功能代碼或名稱）	`"LATE"`

範例：

```
GET /api/v1/iam/system/features?module=HR03&enabled=true
```

Response

成功回應 (200 OK)

欄位	類型	說明
id	String	功能開關ID
featureCode	String	功能代碼
featureName	String	功能名稱
module	String	所屬模組代碼
enabled	Boolean	是否啟用
description	String	功能說明
updatedAt	DateTime	最後更新時間
updatedBy	String	最後更新者

```json
{
  "code": "SUCCESS",
  "message": "查詢成功",
  "data": [
    {
      "id": "feat-uuid-001",
      "featureCode": "LATE_CHECK",
      "featureName": "遲到判定",
      "module": "HR03",
      "enabled": true,
      "description": "啟用後系統自動判定員工遲到並記錄",
      "updatedAt": "2026-01-15T10:00:00Z",
      "updatedBy": "admin"
    },
    {
      "id": "feat-uuid-002",
      "featureCode": "LATE_SALARY_DEDUCTION",
      "featureName": "遲到扣薪",
      "module": "HR03",
      "enabled": true,
      "description": "啟用後遲到自動扣薪計算",
      "updatedAt": "2026-01-15T10:00:00Z",
      "updatedBy": "admin"
    },
    {
      "id": "feat-uuid-003",
      "featureCode": "SHIFT_SCHEDULING",
      "featureName": "輪班排程",
      "module": "HR03",
      "enabled": true,
      "description": "啟用後支援輪班排程功能",
      "updatedAt": "2026-01-10T08:30:00Z",
      "updatedBy": "admin"
    }
  ],
  "timestamp": "2026-03-05T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無 system:feature:read 權限	聯繫管理員授權

7.2 查詢功能開關詳情

基本資訊

項目	內容
端點	`GET /api/v1/iam/system/features/{featureId}`
Controller	`HR01SystemFeatureQryController`
Service	`GetFeatureDetailServiceImpl`
權限	`system:feature:read`
版本	v1

用途說明

查詢單一功能開關的詳細資訊。

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Path Parameters

參數名	類型	必填	說明	範例
featureId	String	✅	功能開關ID	`"feat-uuid-001"`

Response

成功回應 (200 OK)

```json
{
  "code": "SUCCESS",
  "message": "查詢成功",
  "data": {
    "id": "feat-uuid-001",
    "featureCode": "LATE_CHECK",
    "featureName": "遲到判定",
    "module": "HR03",
    "enabled": true,
    "description": "啟用後系統自動判定員工遲到並記錄",
    "tenantId": "550e8400-e29b-41d4-a716-446655440000",
    "updatedAt": "2026-01-15T10:00:00Z",
    "updatedBy": "admin"
  },
  "timestamp": "2026-03-05T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無 system:feature:read 權限	聯繫管理員授權
404	RESOURCE_FEATURE_NOT_FOUND	功能開關不存在	確認 featureId

7.3 更新功能開關

基本資訊

項目	內容
端點	`PUT /api/v1/iam/system/features/{featureId}`
Controller	`HR01SystemFeatureCmdController`
Service	`UpdateFeatureServiceImpl`
權限	`system:feature:write`
版本	v1

用途說明

更新功能開關的啟用/停用狀態，變更即時生效，不需重啟服務。

業務邏輯

1. **權限檢查**

- 必須擁有 system:feature:write 權限
- 僅限 SYSTEM_ADMIN 角色

2. **查詢功能開關**
   - 功能開關不存在則返回 404
3. **更新狀態**
   - 呼叫 FeatureToggle.enable() 或 FeatureToggle.disable()
   - 記錄操作者與更新時間
4. **發布事件**
   - 發布 FeatureToggleChangedEvent

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`
Content-Type	✅	`application/json`

Path Parameters

參數名	類型	必填	說明	範例
featureId	String	✅	功能開關ID	`"feat-uuid-001"`

Request Body

欄位	類型	必填	驗證規則	說明	範例
enabled	Boolean	✅	-	是否啟用	`false`

範例：

```
{
  "enabled": false
}
```

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "功能開關更新成功",
  "data": {
    "id": "feat-uuid-001",
    "featureCode": "LATE_CHECK",
    "featureName": "遲到判定",
    "enabled": false,
    "updatedAt": "2026-03-05T10:30:00Z",
    "updatedBy": "admin"
  },
  "timestamp": "2026-03-05T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無 system:feature:write 權限	聯繫管理員授權
404	RESOURCE_FEATURE_NOT_FOUND	功能開關不存在	確認 featureId

領域事件

事件名稱	Topic	說明
FeatureToggleChangedEvent	`iam.feature-toggle.changed`	功能開關狀態變更

7.4 切換功能開關

基本資訊

項目	內容
端點	`PUT /api/v1/iam/system/features/{featureId}/toggle`
Controller	`HR01SystemFeatureCmdController`
Service	`ToggleFeatureServiceImpl`
權限	`system:feature:write`
版本	v1

用途說明

快速切換功能開關的啟停狀態（toggle），無需指定目標狀態。

業務邏輯

1. **權限檢查**
   - 必須擁有 system:feature:write 權限
2. **查詢功能開關**
   - 功能開關不存在則返回 404
3. **切換狀態**
   - 呼叫 FeatureToggle.toggle()，啟用 → 停用 / 停用 → 啟用
4. **發布事件**
   - 發布 FeatureToggleChangedEvent

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Path Parameters

參數名	類型	必填	說明	範例
featureId	String	✅	功能開關ID	`"feat-uuid-001"`

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "功能開關切換成功",
  "data": {
    "id": "feat-uuid-001",
    "featureCode": "LATE_CHECK",
    "featureName": "遲到判定",
    "enabled": false,
    "updatedAt": "2026-03-05T10:30:00Z",
    "updatedBy": "admin"
  },
  "timestamp": "2026-03-05T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無 system:feature:write 權限	聯繫管理員授權
404	RESOURCE_FEATURE_NOT_FOUND	功能開關不存在	確認 featureId

領域事件

事件名稱	Topic	說明
FeatureToggleChangedEvent	`iam.feature-toggle.changed`	功能開關狀態變更

8. 系統管理API — 系統參數

8.1 查詢系統參數列表

基本資訊

項目	內容
端點	`GET /api/v1/iam/system/configs`
Controller	`HR01SystemConfigQryController`
Service	`GetConfigListServiceImpl`
權限	`system:config:read`
版本	v1

用途說明

查詢系統參數列表，支援依模組、分類篩選。系統參數包含安全設定（如密碼策略）、業務規則（如加班上限）、UI 設定等。加密參數的值不會明文回傳。

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Query Parameters

參數名	類型	必填	說明	範例
module	String	☐	模組代碼篩選（GLOBAL 或 HR01-HR14）	`"GLOBAL"`
category	String	☐	參數分類（SECURITY/BUSINESS/UI/SYSTEM）	`"SECURITY"`
keyword	String	☐	模糊搜尋（參數代碼或名稱）	`"PASSWORD"`
page	Integer	☐	頁碼（從1開始，預設1）	`1`
size	Integer	☐	每頁筆數（預設20，最大100）	`20`

範例：

```
GET /api/v1/iam/system/configs?module=GLOBAL&category=SECURITY&page=1&size=20
```

Response

成功回應 (200 OK)

欄位	類型	說明
id	String	參數ID
paramCode	String	參數代碼
paramName	String	參數名稱
paramValue	String	參數值（加密參數顯示 `"******"` ）
paramType	String	參數型別（STRING/INTEGER/DECIMAL/BOOLEAN/JSON）
module	String	所屬模組代碼
category	String	參數分類
description	String	參數說明
defaultValue	String	預設值
isEncrypted	Boolean	是否加密儲存
updatedAt	DateTime	最後更新時間
updatedBy	String	最後更新者

```json
{
  "code": "SUCCESS",
  "message": "查詢成功",
  "data": {
    "content": [
      {
        "id": "config-uuid-001",
        "paramCode": "MAX_FAILED_LOGIN_ATTEMPTS",
        "paramName": "最大登入失敗次數",
        "paramValue": "5",
        "paramType": "INTEGER",
        "module": "GLOBAL",
        "category": "SECURITY",
        "description": "連續登入失敗達此次數後鎖定帳號",
        "defaultValue": "5",
        "isEncrypted": false,
        "updatedAt": "2026-01-10T08:00:00Z",
        "updatedBy": "admin"
      },
      {
        "id": "config-uuid-002",
        "paramCode": "ACCOUNT_LOCK_DURATION_MINUTES",
        "paramName": "帳號鎖定時間（分鐘）",
        "paramValue": "30",
        "paramType": "INTEGER",
        "module": "GLOBAL",
        "category": "SECURITY",
        "description": "帳號被鎖定後的自動解鎖時間",
        "defaultValue": "30",
        "isEncrypted": false,
        "updatedAt": "2026-01-10T08:00:00Z",
        "updatedBy": "admin"
      },
      {
        "id": "config-uuid-003",
        "paramCode": "PASSWORD_EXPIRY_DAYS",
        "paramName": "密碼有效天數",
        "paramValue": "90",
        "paramType": "INTEGER",
        "module": "GLOBAL",
        "category": "SECURITY",
        "description": "密碼有效天數，超過後強制修改密碼",
        "defaultValue": "90",
        "isEncrypted": false,
        "updatedAt": "2026-01-10T08:00:00Z",
        "updatedBy": "admin"
      }
    ],
    "page": 1,
    "size": 20,
    "totalElements": 3,
```

```
    "totalPages": 1
  },
  "timestamp": "2026-03-05T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無 system:config:read 權限	聯繫管理員授權

8.2 查詢系統參數詳情

基本資訊

項目	內容
端點	`GET /api/v1/iam/system/configs/{configId}`
Controller	`HR01SystemConfigQryController`
Service	`GetConfigDetailServiceImpl`
權限	`system:config:read`
版本	v1

用途說明

查詢單一系統參數的詳細資訊，包含預設值與加密標記。

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Path Parameters

參數名	類型	必填	說明	範例
configId	String	✅	系統參數ID	`"config-uuid-001"`

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "查詢成功",
  "data": {
    "id": "config-uuid-001",
    "paramCode": "MAX_FAILED_LOGIN_ATTEMPTS",
    "paramName": "最大登入失敗次數",
    "paramValue": "5",
    "paramType": "INTEGER",
    "module": "GLOBAL",
    "category": "SECURITY",
    "description": "連續登入失敗達此次數後鎖定帳號",
    "defaultValue": "5",
    "isEncrypted": false,
    "tenantId": "550e8400-e29b-41d4-a716-446655440000",
    "updatedAt": "2026-01-10T08:00:00Z",
    "updatedBy": "admin"
  },
  "timestamp": "2026-03-05T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無 system:config:read 權限	聯繫管理員授權
404	RESOURCE_CONFIG_NOT_FOUND	系統參數不存在	確認 configId

8.3 更新系統參數

基本資訊

項目	內容
端點	`PUT /api/v1/iam/system/configs/{configId}`
Controller	`HR01SystemConfigCmdController`
Service	`UpdateConfigServiceImpl`
權限	`system:config:write`
版本	v1

用途說明

更新系統參數的值。系統會自動驗證參數型別，並記錄異動歷史（audit trail），包含舊值與新值。加密參數（如密碼、密鑰）會以加密方式儲存。

業務邏輯

1. **權限檢查**
   - 必須擁有 system:config:write 權限
   - 僅限 SYSTEM_ADMIN 角色
2. **查詢參數**
   - 參數不存在則返回 404
3. **驗證新值**
   - 依據 paramType 驗證值的格式：
     - INTEGER：必須為有效整數
     - DECIMAL：必須為有效小數
     - BOOLEAN：必須為 `true` 或 `false`
     - JSON：必須為有效 JSON 格式
4. **更新參數**
   - 呼叫 SystemParameter.updateValue()
   - 回傳 ParameterChange 記錄（含 oldValue/newValue）
   - 寫入 parameter_change_logs 表
5. **發布事件**
   - 發布 SystemParameterChangedEvent

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`
Content-Type	✅	`application/json`

Path Parameters

參數名	類型	必填	說明	範例
configId	String	✅	系統參數ID	`"config-uuid-001"`

Request Body

欄位	類型	必填	驗證規則	說明	範例
paramValue	String	✅	必須符合 paramType 格式	新參數值	`"10"`

範例：

```
{
  "paramValue": "10"
}
```

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "系統參數更新成功",
  "data": {
    "id": "config-uuid-001",
    "paramCode": "MAX_FAILED_LOGIN_ATTEMPTS",
    "paramName": "最大登入失敗次數",
    "paramValue": "10",
    "paramType": "INTEGER",
    "changeLog": {
      "oldValue": "5",
      "newValue": "10",
      "operator": "admin",
      "changedAt": "2026-03-05T10:30:00Z"
    },
    "updatedAt": "2026-03-05T10:30:00Z",
    "updatedBy": "admin"
  },
  "timestamp": "2026-03-05T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
400	VALIDATION_PARAM_TYPE_MISMATCH	參數值與型別不符	檢查參數型別，輸入正確格式的值
400	VALIDATION_PARAM_VALUE_INVALID	參數值無效	檢查參數值是否在允許範圍內
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無 system:config:write 權限	聯繫管理員授權
404	RESOURCE_CONFIG_NOT_FOUND	系統參數不存在	確認 configId

領域事件

事件名稱	Topic	說明
SystemParameterChangedEvent	`iam.system-parameter.changed`	系統參數值變更

8.4 重設系統參數為預設值

基本資訊

項目	內容
端點	`PUT /api/v1/iam/system/configs/{configId}/reset`
Controller	`HR01SystemConfigCmdController`
Service	`ResetConfigServiceImpl`
權限	`system:config:write`
版本	v1

用途說明

將系統參數重設為預設值，並記錄異動歷史。

業務邏輯

1. **權限檢查**
   - 必須擁有 system:config:write 權限
2. **查詢參數**
   - 參數不存在則返回 404
3. **重設為預設值**

- 呼叫 SystemParameter.resetToDefault()
- 回傳 ParameterChange 記錄
- 寫入 parameter_change_logs 表

4. **發布事件**
   - 發布 SystemParameterChangedEvent

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Path Parameters

參數名	類型	必填	說明	範例
configId	String	✅	系統參數ID	`"config-uuid-001"`

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "系統參數已重設為預設值",
  "data": {
    "id": "config-uuid-001",
    "paramCode": "MAX_FAILED_LOGIN_ATTEMPTS",
    "paramName": "最大登入失敗次數",
    "paramValue": "5",
    "paramType": "INTEGER",
    "changeLog": {
      "oldValue": "10",
      "newValue": "5",
      "operator": "admin",
      "changedAt": "2026-03-05T10:30:00Z"
    },
    "updatedAt": "2026-03-05T10:30:00Z",
    "updatedBy": "admin"
  },
  "timestamp": "2026-03-05T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無 system:config:write 權限	聯繫管理員授權
404	RESOURCE_CONFIG_NOT_FOUND	系統參數不存在	確認 configId

領域事件

事件名稱	Topic	說明
SystemParameterChangedEvent	`iam.system-parameter.changed`	系統參數值變更（重設為預設值）

9. 系統管理API — 排程管理

9.1 查詢排程列表

基本資訊

項目	內容
端點	`GET /api/v1/iam/system/schedulers`
Controller	`HR01SystemSchedulerQryController`
Service	`GetSchedulerListServiceImpl`
權限	`system:scheduler:read`
版本	v1

用途說明

查詢系統排程任務列表，支援依模組、狀態篩選。排程任務包含考勤日結、薪資月結、保險申報、特休年結等自動化任務。

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Query Parameters

參數名	類型	必填	說明	範例
module	String	☐	模組代碼篩選（HR01-HR14）	`"HR03"`
enabled	Boolean	☐	僅顯示啟用/停用的排程	`true`
status	String	☐	最近執行狀態（SUCCESS/FAILED/RUNNING）	`"FAILED"`

範例：

```
GET /api/v1/iam/system/schedulers?module=HR03&enabled=true
```

Response

成功回應 (200 OK)

欄位	類型	說明
id	String	排程ID
jobCode	String	任務代碼
jobName	String	任務名稱
module	String	所屬模組代碼
cronExpression	String	Cron 表達式
enabled	Boolean	是否啟用
description	String	任務說明
lastExecutedAt	DateTime	最近執行時間
lastExecutionStatus	String	最近執行狀態（SUCCESS/FAILED/RUNNING）
lastErrorMessage	String	最近錯誤訊息（僅 FAILED 時有值）
consecutiveFailures	Integer	連續失敗次數
updatedAt	DateTime	最後更新時間
updatedBy	String	最後更新者

```
{
  "code": "SUCCESS",
  "message": "查詢成功",
  "data": [
    {
      "id": "sched-uuid-001",
      "jobCode": "ABSENT_DETECTION",
      "jobName": "曠職判定",
      "module": "HR03",
      "cronExpression": "0 0 19 * * ?",
      "enabled": true,
      "description": "每日 19:00 自動判定曠職",
      "lastExecutedAt": "2026-03-04T19:00:00Z",
      "lastExecutionStatus": "SUCCESS",
      "lastErrorMessage": null,
      "consecutiveFailures": 0,
      "updatedAt": "2026-01-10T08:00:00Z",
      "updatedBy": "admin"
    },
    {
      "id": "sched-uuid-002",
      "jobCode": "ANNUAL_LEAVE_SETTLEMENT",
      "jobName": "特休年度結算",
      "module": "HR03",
      "cronExpression": "0 0 1 1 1 ?",
      "enabled": true,
      "description": "每年 1/1 自動結算特休假",
      "lastExecutedAt": "2026-01-01T01:00:00Z",
      "lastExecutionStatus": "SUCCESS",
      "lastErrorMessage": null,
      "consecutiveFailures": 0,
      "updatedAt": "2026-01-10T08:00:00Z",
      "updatedBy": "admin"
    },
    {
      "id": "sched-uuid-003",
      "jobCode": "INSURANCE_DAILY_REPORT",
      "jobName": "保險異動報表",
      "module": "HR05",
      "cronExpression": "0 30 8 * * ?",
      "enabled": true,
      "description": "每日 08:30 產生保險異動報表",
      "lastExecutedAt": "2026-03-05T08:30:00Z",
      "lastExecutionStatus": "FAILED",
      "lastErrorMessage": "連線逾時：保險局 API 無回應",
      "consecutiveFailures": 2,
      "updatedAt": "2026-01-10T08:00:00Z",
      "updatedBy": "admin"
    },
    {
      "id": "sched-uuid-004",
```

```
      "jobCode": "PAYROLL_MONTHLY_CLOSE",
      "jobName": "薪資月結",
      "module": "HR04",
      "cronExpression": "0 0 2 1 * ?",
      "enabled": true,
      "description": "每月 1 日 02:00 執行薪資月結",
      "lastExecutedAt": "2026-03-01T02:00:00Z",
      "lastExecutionStatus": "SUCCESS",
      "lastErrorMessage": null,
      "consecutiveFailures": 0,
      "updatedAt": "2026-01-10T08:00:00Z",
      "updatedBy": "admin"
    }
  ],
  "timestamp": "2026-03-05T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無 system:scheduler:read 權限	聯繫管理員授權

9.2 查詢排程詳情

基本資訊

項目	內容
端點	`GET /api/v1/iam/system/schedulers/{schedulerId}`
Controller	`HR01SystemSchedulerQryController`
Service	`GetSchedulerDetailServiceImpl`
權限	`system:scheduler:read`
版本	v1

用途說明

查詢單一排程任務的詳細資訊，包含最近執行狀態與連續失敗次數。

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Path Parameters

參數名	類型	必填	說明	範例
schedulerId	String	✅	排程ID	`"sched-uuid-001"`

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "查詢成功",
  "data": {
    "id": "sched-uuid-001",
    "jobCode": "ABSENT_DETECTION",
    "jobName": "曠職判定",
    "module": "HR03",
    "cronExpression": "0 0 19 * * ?",
    "enabled": true,
    "description": "每日 19:00 自動判定曠職",
    "lastExecutedAt": "2026-03-04T19:00:00Z",
    "lastExecutionStatus": "SUCCESS",
    "lastErrorMessage": null,
    "consecutiveFailures": 0,
    "tenantId": "550e8400-e29b-41d4-a716-446655440000",
    "updatedAt": "2026-01-10T08:00:00Z",
    "updatedBy": "admin"
  },
  "timestamp": "2026-03-05T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無 system:scheduler:read 權限	聯繫管理員授權
404	RESOURCE_SCHEDULER_NOT_FOUND	排程任務不存在	確認 schedulerId

9.3 更新排程配置

基本資訊

項目	內容
端點	`PUT /api/v1/iam/system/schedulers/{schedulerId}`
Controller	`HR01SystemSchedulerCmdController`
Service	`UpdateSchedulerServiceImpl`
權限	`system:scheduler:write`
版本	v1

用途說明

更新排程任務的 Cron 表達式與啟停狀態。可用於調整排程執行時間或暫停排程任務。

業務邏輯

1. **權限檢查**
   - 必須擁有 system:scheduler:write 權限
   - 僅限 SYSTEM_ADMIN 角色
2. **查詢排程**
   - 排程不存在則返回 404
3. **驗證 Cron 表達式**
   - 若有提供 cronExpression，驗證格式是否為有效的 Cron 表達式
   - 支援 6 位（秒 分 時 日 月 週）或 7 位（含年）格式
4. **更新排程**
   - 更新 cronExpression（若有提供）→ 呼叫 ScheduledJobConfig.updateCron()
   - 更新 enabled（若有提供）→ 呼叫 enable() 或 disable()
5. **發布事件**
   - 發布 SchedulerConfigChangedEvent

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`
Content-Type	✅	`application/json`

Path Parameters

參數名	類型	必填	說明	範例
schedulerId	String	✅	排程ID	`"sched-uuid-001"`

Request Body

欄位	類型	必填	驗證規則	說明	範例
cronExpression	String	⬚	有效的 Cron 表達式	Cron 表達式	`"0 0 20 * * ?"`
enabled	Boolean	⬚	-	是否啟用	`true`

範例：

```
{
  "cronExpression": "0 0 20 * * ?",
  "enabled": true
}
```

Response

成功回應 (200 OK)

```
{
  "code": "SUCCESS",
  "message": "排程配置更新成功",
  "data": {
    "id": "sched-uuid-001",
    "jobCode": "ABSENT_DETECTION",
    "jobName": "曠職判定",
    "cronExpression": "0 0 20 * * ?",
    "enabled": true,
    "updatedAt": "2026-03-05T10:30:00Z",
    "updatedBy": "admin"
  },
  "timestamp": "2026-03-05T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
400	VALIDATION_CRON_INVALID	Cron 表達式格式無效	檢查 Cron 表達式是否正確
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無 system:scheduler:write 權限	聯繫管理員授權
404	RESOURCE_SCHEDULER_NOT_FOUND	排程任務不存在	確認 schedulerId

領域事件

事件名稱	Topic	說明
SchedulerConfigChangedEvent	`iam.scheduler-config.changed`	排程配置變更

9.4 手動觸發排程

基本資訊

項目	內容
端點	`POST /api/v1/iam/system/schedulers/{schedulerId}/trigger`
Controller	`HR01SystemSchedulerCmdController`
Service	`TriggerSchedulerServiceImpl`
權限	`system:scheduler:execute`
版本	v1

用途說明

手動觸發排程任務立即執行，不受 Cron 排程時間限制。適用於排程失敗後手動重試或臨時需要執行的場景。

業務邏輯

1. **權限檢查**
   - 必須擁有 system:scheduler:execute 權限
   - 僅限 SYSTEM_ADMIN 角色
2. **查詢排程**
   - 排程不存在則返回 404

- 若排程正在執行中（lastExecutionStatus = RUNNING），返回 409

3. **觸發執行**
   - 呼叫 ScheduledJobConfig.recordStart()
   - 非同步執行排程任務
   - 執行完成後呼叫 recordSuccess() 或 recordFailure()
4. **告警檢查**
   - 若 consecutiveFailures >= 3，觸發 SchedulerAlertEvent

Request

Headers

名稱	必填	說明
Authorization	✅	`Bearer {accessToken}`

Path Parameters

參數名	類型	必填	說明	範例
schedulerId	String	✅	排程ID	`"sched-uuid-003"`

Response

成功回應 (202 Accepted)

```
{
  "code": "SUCCESS",
  "message": "排程任務已觸發執行",
  "data": {
    "id": "sched-uuid-003",
    "jobCode": "INSURANCE_DAILY_REPORT",
    "jobName": "保險異動報表",
    "lastExecutionStatus": "RUNNING",
    "triggeredAt": "2026-03-05T10:30:00Z",
    "triggeredBy": "admin"
  },
  "timestamp": "2026-03-05T10:30:00Z"
}
```

錯誤碼

HTTP	錯誤碼	說明	處理建議
401	AUTH_TOKEN_INVALID	Token無效	重新登入
403	AUTHZ_PERMISSION_DENIED	無 system:scheduler:execute 權限	聯繫管理員授權
404	RESOURCE_SCHEDULER_NOT_FOUND	排程任務不存在	確認 schedulerId
409	BUSINESS_SCHEDULER_ALREADY_RUNNING	排程任務正在執行中	等待目前執行完畢後再觸發

領域事件

事件名稱	Topic	說明
SchedulerTriggeredEvent	`iam.scheduler.triggered`	排程任務被手動觸發
SchedulerAlertEvent	`iam.scheduler.alert`	排程連續失敗告警（consecutiveFailures >= 3）

---

10. 錯誤碼總覽

10.1 認證相關 (AUTH_)

錯誤碼	HTTP	說明
AUTH_INVALID_CREDENTIALS	401	使用者名稱或密碼錯誤
AUTH_TOKEN_INVALID	401	Token無效
AUTH_TOKEN_EXPIRED	401	Token已過期
AUTH_REFRESH_TOKEN_INVALID	401	Refresh Token無效
AUTH_REFRESH_TOKEN_EXPIRED	401	Refresh Token已過期
AUTH_ACCOUNT_DISABLED	403	帳號已停用
AUTH_ACCOUNT_LOCKED	423	帳號已被鎖定
AUTH_RESET_TOKEN_INVALID	400	重置Token無效
AUTH_RESET_TOKEN_EXPIRED	400	重置Token已過期
AUTH_CURRENT_PASSWORD_WRONG	401	當前密碼錯誤

10.2 授權相關 (AUTHZ_)

錯誤碼	HTTP	說明
AUTHZ_PERMISSION_DENIED	403	無此操作權限

10.3 驗證相關 (VALIDATION_)

錯誤碼	HTTP	說明
VALIDATION_EMAIL_FORMAT	400	Email格式不正確
VALIDATION_PASSWORD_REQUIRED	400	密碼為必填
VALIDATION_PASSWORD_WEAK	400	密碼強度不足
VALIDATION_PASSWORD_MISMATCH	400	兩次密碼不一致
VALIDATION_PASSWORD_SAME_AS_OLD	400	新密碼不能與舊密碼相同
VALIDATION_PASSWORD_RECENTLY_USED	400	新密碼不能與近期密碼相同
VALIDATION_ROLE_REQUIRED	400	至少需指派一個角色
VALIDATION_ROLE_NAME_FORMAT	400	角色代碼格式不正確
VALIDATION_USER_IDS_REQUIRED	400	至少需選擇一個使用者
VALIDATION_USER_IDS_TOO_MANY	400	超過批次上限
VALIDATION_PARAM_TYPE_MISMATCH	400	參數值與型別不符
VALIDATION_PARAM_VALUE_INVALID	400	參數值無效
VALIDATION_CRON_INVALID	400	Cron 表達式格式無效

10.4 資源相關 (RESOURCE_)

錯誤碼	HTTP	說明
RESOURCE_USER_NOT_FOUND	404	使用者不存在
RESOURCE_USER_EXISTS	409	使用者帳號已存在
RESOURCE_EMPLOYEE_NOT_FOUND	404	員工不存在
RESOURCE_EMPLOYEE_HAS_USER	409	該員工已有帳號
RESOURCE_ROLE_NOT_FOUND	404	角色不存在
RESOURCE_ROLE_EXISTS	409	角色代碼已存在
RESOURCE_PERMISSION_NOT_FOUND	404	權限不存在
RESOURCE_FEATURE_NOT_FOUND	404	功能開關不存在
RESOURCE_CONFIG_NOT_FOUND	404	系統參數不存在
RESOURCE_SCHEDULER_NOT_FOUND	404	排程任務不存在

10.5 業務邏輯相關 (BUSINESS_)

錯誤碼	HTTP	說明
BUSINESS_USER_ALREADY_INACTIVE	422	使用者已停用
BUSINESS_USER_ALREADY_ACTIVE	422	使用者已啟用
BUSINESS_SYSTEM_ROLE_READONLY	422	系統預設角色不可修改/刪除
BUSINESS_ROLE_IN_USE	422	角色仍有使用者使用
BUSINESS_SCHEDULER_ALREADY_RUNNING	409	排程任務正在執行中

11. 領域事件總覽

11.1 事件清單

事件名稱	Topic	觸發時機	訂閱服務
UserCreatedEvent	`iam.user.created`	建立使用者	Organization, Notification
UserUpdatedEvent	`iam.user.updated`	更新使用者資料	-
UserDeactivatedEvent	`iam.user.deactivated`	停用使用者	Notification
UserActivatedEvent	`iam.user.activated`	啟用使用者	-
UserLoggedInEvent	`iam.user.logged-in`	登入成功	-
AccountLockedEvent	`iam.account.locked`	帳號鎖定	Notification
PasswordChangedEvent	`iam.password.changed`	修改密碼	Notification
PasswordResetEvent	`iam.password.reset`	重置密碼	Notification
PasswordResetRequestedEvent	`iam.password.reset-requested`	申請密碼重置	Notification
PasswordResetByAdminEvent	`iam.password.reset-by-admin`	管理員重置密碼	Notification
RoleCreatedEvent	`iam.role.created`	建立角色	-
RoleUpdatedEvent	`iam.role.updated`	更新角色	-
RoleDeletedEvent	`iam.role.deleted`	刪除角色	-
RolePermissionChangedEvent	`iam.role.permission-changed`	角色權限變更	(快取失效)
UserRoleAssignedEvent	`iam.user.role-assigned`	指派角色給使用者	(快取失效)
FeatureToggleChangedEvent	`iam.feature-toggle.changed`	功能開關狀態變更	各模組（即時生效）
SystemParameterChangedEvent	`iam.system-parameter.changed`	系統參數值變更	各模組（參數快取失效）
SchedulerConfigChangedEvent	`iam.scheduler-config.changed`	排程配置變更	Scheduler Engine
SchedulerTriggeredEvent	`iam.scheduler.triggered`	排程任務被手動觸發	Scheduler Engine
SchedulerAlertEvent	`iam.scheduler.alert`	排程連續失敗告警	Notification

11.2 事件 Payload 結構

所有事件均遵循以下基本結構：

```
{
  "eventId": "uuid",
  "eventType": "事件類型名稱",
  "occurredAt": "2025-12-29T10:30:00Z",
  "aggregateId": "聚合根ID",
  "aggregateType": "聚合根類型",
  "payload": {
    // 事件特定資料
  },
  "metadata": {
    "correlationId": "關聯ID",
    "causationId": "因果ID",
    "userId": "操作者ID",
    "tenantId": "租戶ID"
  }
}
```

附錄 A：欄位類型對照

類型	Java	TypeScript	說明
String	String	string	字串
Integer	Integer	number	整數
Long	Long	number	長整數
Boolean	Boolean	boolean	布林值
UUID	UUID	string	UUID字串
DateTime	LocalDateTime	string	日期時間 (ISO 8601)
Enum	Enum	string	列舉值
Array	List	T[]	陣列

附錄 B：列舉值定義

B.1 UserStatus (使用者狀態)

值	說明
ACTIVE	啟用
INACTIVE	停用
LOCKED	鎖定

文件建立日期: 2025-12-29 **最後更新日期:** 2026-03-05 **版本:** 1.1（新增系統管理 API：功能開關、系統參數、排程管理，共 12 個端點）